

Security+ 1.2 · Gap Analysis

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 1.2 — Gap Analysis (6:44)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Gap analysis compares the current security posture against a desired framework (e.g., NIST CSF, ISO 27001) to identify missing controls. The gap is the delta between current and target states, and it feeds the improvement roadmap and risk register.

High-Yield Core Concepts Tested on Exam

- Gap analysis feeds the risk register
- It is the FIRST step in framework implementation
- Compares current state vs. desired state (NIST CSF, ISO 27001)
- Identifies missing controls and prioritizes remediation
- Output drives the security improvement roadmap

Exam Tips & Classic Scenarios

- Exam trigger: 'organization checks its security posture against NIST CSF' = gap analysis
- If the question mentions comparing current vs. desired state, think gap analysis
- Gap analysis is not a one-time task; it is iterative and feeds continuous improvement

Typical Exam Scenario: A company compares its current security controls with the NIST CSF to identify what is missing and prioritize improvements. This is an example of gap analysis.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 1.2 — Gap Analysis)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. The new security leadership of a fintech wants to understand the company's maturity level relative to the NIST Cybersecurity Framework (CSF) to define next year's cybersecurity budget. What is the formal assessment indicated to map the current situation versus the framework requirements?

- A)** Gap Analysis
- B)** Port scan with Nmap
- C)** Red Team penetration test
- D)** Network performance audit

2. What is the main output (deliverable) produced at the end of a Gap Analysis process?

- A)** A prioritized action and remediation plan to achieve compliance
- B)** The dismissal of employees who made operational errors
- C)** The immediate purchase of expensive tools without prior study
- D)** A certificate of immunity to cyber attacks

3. A company that processes credit card payments needs to comply with PCI DSS v4.0. During a Gap Analysis, the team finds that service account passwords are not automatically rotated. This finding represents:

- A)** A compliance 'gap' (control gap) that must be remediated
- B)** An approved compensating control
- C)** An irrelevant false positive for the audit
- D)** A violation that requires no action if the firewall is active

4. What is the primary difference between a Vulnerability Assessment and a Gap Analysis?

- A)** Vulnerability assessment seeks technical flaws in systems (software/ports); Gap Analysis compares processes and policies to security standards and frameworks
- B)** Gap Analysis only analyzes source code; vulnerability assessment only analyzes contracts
- C)** Both are identical and run the same scanning tools
- D)** Gap Analysis is performed exclusively by external attackers

5. When conducting a Gap Analysis against the ISO/IEC 27001 framework, what is the role of the Statement of Applicability (SoA)?

- A)** Document which Annex A controls are applicable to the company and justify the exclusion of the others
- B)** List all IP addresses of the company's servers
- C)** Describe the database encryption algorithm
- D)** Record the employment contract of administrators

6. During a Gap Analysis, the security team discovers that a policy requires two-factor authentication for all employees, but the sales department has been using only username and password for over a year. This evidences a gap in:

- A)** Implementation and operational compliance (the policy exists on paper but is not enforced in practice)
- B)** Lack of management documentation
- C)** Hardware failure in the database server
- D)** Incompatibility with labor laws

7. At what point in the implementation lifecycle of an information security program should a Gap Analysis be primarily executed?

- A)** In the initial planning and diagnostic phase, before acquiring new solutions
- B)** Only after a large-scale cyberattack
- C)** At the definitive closure of the company's operations
- D)** Exclusively before hiring interns

8. Which maturity indicator is frequently used in Gap Analysis reports to measure the evolution of an organization's security processes?

- A)** CMMI (Capability Maturity Model Integration) with levels 1 to 5
- B)** Log file size in Gigabytes
- C)** Number of emails received by the board of directors
- D)** Download speed of the fiber connection

9. A Gap Analysis report identified 45 security gaps. How should the CISO prioritize the remediation plan before the executive board?

- A)** Based on business risk impact, likelihood of occurrence, and mandatory regulatory requirements
- B)** Remediating only the easiest and quickest tasks first
- C)** By the highest cost of tools available on the market
- D)** In alphabetical order of the affected department names

10. A company acquires a competing startup. Before connecting the two corporate networks, the security team performs a mutual Gap Analysis. What is the objective of this due diligence measure?

- A)** Identify security weaknesses in the acquired company that could compromise the acquiring company's network
- B)** Reduce the salaries of the startup's engineers
- C)** Install spyware to monitor the conversations of the acquired team
- D)** Erase the email history of the acquired company

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — Gap Analysis.

✓ **Why it's correct:** Gap Analysis is the formal assessment indicated to map an organization's current state of controls, processes, and security posture against a reference framework such as the NIST CSF. In the context of SY0-701, Gap Analysis is classified as a compliance and maturity assessment because it compares the 'as-is' state with the 'to-be' state defined by the framework. The NIST CSF is organized into five functions (Identify, Protect, Detect, Respond, Recover) and categories/subcategories. Gap Analysis walks through each subcategory, verifies whether a control is implemented, documented, operating, and audited, and identifies gaps. The result feeds budget planning, prioritizing investments where maturity is low and risk is high. It is an assessment based on documentary evidence, interviews, and observation, not active technical exploitation.

✗ **Why the others are wrong:**

- *Port scan with Nmap:* Nmap port scanning is an active reconnaissance technique that discovers open TCP/UDP ports, running services, and sometimes software versions. It produces a technical map of the attack surface of specific hosts but does not evaluate policies, procedures, governance, risk management, incident response, or any of the NIST CSF functions. It is a tactical discovery tool, not a formal organizational maturity assessment. Therefore, it does not provide the holistic view needed to define a cybersecurity budget based on the CSF.
- *Red Team penetration test:* A Red Team penetration test simulates real adversaries to evaluate detection and response effectiveness, exploiting technical and human vulnerabilities. It measures operational resilience in an attack scenario but does not compare the organization against NIST CSF requirements in a structured way. Its scope is offensive and point-in-time, not covering governance, asset management, awareness, business continuity, or continuous improvement. Additionally, a Red Team does not produce a gap map by CSF subcategory, making it unsuitable for maturity-based budget planning.
- *Network performance audit:* A network performance audit focuses on throughput, latency, jitter, packet loss, availability, and capacity metrics. Although it may reveal availability issues that affect security, it does not assess security controls, framework compliance, risk management, or process maturity. It is a network engineering assessment, not an information security one. It does not provide input to map the current situation versus NIST CSF requirements, and is therefore inapplicable to the described objective.

2) A — A prioritized action and remediation plan to achieve compliance.

✓ **Why it is correct:** The main deliverable of a Gap Analysis is a prioritized action and remediation plan. This plan documents each identified gap, the missing control or practice, the associated risk, the treatment priority (based on criticality, exposure, and impact), responsible parties, deadlines, and required resources. In the context of SY0-701, Gap Analysis is an assessment activity that feeds the continuous improvement and risk management cycle. The plan enables leadership to make informed decisions about investments, staffing, and process changes, transforming findings into an actionable roadmap to achieve the desired compliance or maturity.

✗ **Why the others are wrong:**

- *The dismissal of employees who made operational errors:* Dismissing employees for operational errors is a punitive and counterproductive measure. Gap Analysis identifies systemic, process, or control gaps, not individual blame. A mature security culture encourages error reporting and continuous improvement, not punishment. Moreover, dismissal does not resolve the control gap and may increase risk due to loss of knowledge. Therefore, it is not a Gap Analysis deliverable.
- *The immediate purchase of expensive tools without prior study:* Immediate purchase of tools

without prior study is a reactive and ineffective approach. Gap Analysis produces a prioritized plan that justifies each investment based on identified risk and gap. Buying tools before understanding needs can lead to unnecessary spending, overlapping controls, and a false sense of security. The correct deliverable is the action plan, not impulsive acquisition.

- *A certificate of immunity to cyber attacks:* There is no certificate of immunity to cyber attacks. No assessment, framework, or control guarantees total immunity. Security is a continuous risk management process, and Gap Analysis identifies gaps to reduce them, but does not eliminate all risks. Promising immunity would be unethical and technically incorrect. Therefore, this is not a valid deliverable.

3) A — A compliance 'gap' (control gap) that must be remediated.

✓ **Why it is correct:** The lack of automatic rotation of service account passwords is a compliance 'gap' (control gap) with PCI DSS v4.0. Requirement 8.3.9 of PCI DSS v4.0 requires that service account passwords be changed periodically and that authentication controls be managed. The absence of automatic rotation means the organization does not meet this requirement, constituting a gap that must be remediated. Gap Analysis identifies exactly this type of discrepancy between the current state and the standard's requirements, and the finding must be recorded, prioritized, and addressed with an action plan.

✗ Why the others are wrong:

- *An approved compensating control:* A compensating control is an alternative measure that provides equivalent protection to the original requirement, formally approved by the Qualified Security Assessor (QSA) or the organization. The absence of password rotation is not a compensating control; it is the lack of a required control. To be compensating, another mechanism would be necessary to mitigate the risk of static passwords, such as multi-factor authentication for service accounts or a password vault with managed rotation. Without formal approval and proven equivalence, it is not a compensating control.

- *An irrelevant false positive for the audit:* A false positive is an incorrect alert generated by a scanning or monitoring tool. In the context of a Gap Analysis, the finding is based on documentary evidence and direct observation, not an automated alert. The absence of password rotation is a verifiable fact relevant to PCI DSS compliance. Ignoring it as a false positive would be negligence and could result in non-compliance during the audit.

- *A violation that requires no action if the firewall is active:* An active firewall does not compensate for the lack of service account password rotation. The firewall controls network traffic but does not prevent the misuse of static credentials by attackers who are already on the network or who obtain passwords through other means. PCI DSS requires authentication controls regardless of other perimeter controls. Therefore, the statement is incorrect and dangerous, as it ignores the principle of defense in depth and the specific requirement of the standard.

4) A — Vulnerability assessment seeks technical flaws in systems (software/ports); Gap Analysis compares processes and policies to security standards and frameworks.

✓ **Why it's correct:** The primary difference is that a Vulnerability Assessment seeks technical flaws in systems, such as outdated software, open ports, insecure configurations, and known vulnerabilities (CVEs), using scanning tools. Gap Analysis, on the other hand, compares organizational processes, policies, procedures, and controls to security standards, frameworks, and benchmarks (e.g., NIST CSF, ISO 27001, PCI DSS). While the former is technical and focused on IT assets, the latter is strategic and covers governance, risk management, compliance, and maturity. In SY0-701, this distinction is fundamental to choosing the appropriate assessment for the objective.

✗ Why the others are wrong:

- *Gap Analysis only analyzes source code; vulnerability assessment only analyzes contracts:* This statement completely reverses the concepts. Gap Analysis is not limited to source code; it evaluates processes, policies, and controls across the organization. Vulnerability assessment does not analyze contracts; it examines technical systems. Therefore, the alternative is factually incorrect and demonstrates confusion about the scopes of the two assessments.
- *Both are identical and run the same scanning tools:* The two assessments are not identical. Vulnerability Assessment uses scanners such as Nessus, Qualys, or OpenVAS to identify technical flaws. Gap Analysis uses questionnaires, interviews, document review, and compliance matrices to compare practices with requirements. The tools and methodologies are distinct, as are the results: a technical vulnerability report versus an action plan for compliance gaps.
- *Gap Analysis is performed exclusively by external attackers:* Gap Analysis is conducted by internal professionals or security consultants, auditors, or compliance teams, not by external attackers. External attackers perform penetration tests or real attacks, not formal gap analyses. Gap Analysis requires access to documentation, policies, and personnel, which is not typical of an external attacker. Therefore, the statement is incorrect.

5) A — Document which Annex A controls are applicable to the company and justify the exclusion of the others.

✓ **Why it's correct:** The Statement of Applicability (SoA) is a mandatory document in an Information Security Management System (ISMS) based on ISO/IEC 27001. Its role is to document which Annex A controls are applicable to the organization, justifying the inclusion and exclusion of each. During a Gap Analysis against ISO 27001, the SoA serves as a reference to verify whether the controls declared as applicable are effectively implemented and operating. It also evidences the risk analysis that underpinned the selection of controls, being a central artifact for certification audits.

✗ Why the others are wrong:

- *List all IP addresses of the company's servers:* Listing IP addresses is a network asset inventory activity, not the purpose of the SoA. The SoA deals with security controls from ISO 27001 Annex A, not infrastructure details. An IP inventory may be part of asset management (control A.8.1), but it is not the SoA. Therefore, this alternative confuses a control management artifact with a technical network record.
- *Describe the database encryption algorithm:* Describing encryption algorithms is technical documentation of control implementation, not the SoA. The SoA indicates whether the encryption control (A.8.24) is applicable and implemented, but does not go into algorithmic details. The algorithm description may be in specific policies or procedures, but it is not the role of the SoA. Therefore, this alternative is incorrect.
- *Record the employment contract of administrators:* Employment contracts are human resources documents, not the SoA. ISO 27001 has controls related to terms and conditions of employment (A.6.1) and responsibilities (A.5.2), but the SoA only declares the applicability of these controls and the justification. The contract itself is evidence of implementation, not the SoA. Therefore, this alternative confuses a legal document with the statement of applicability artifact.

6) A — Implementation and operational compliance (the policy exists on paper but is not enforced in practice).

✓ **Why it is correct:** The correct alternative is 'Implementation and operational compliance (the policy exists on paper but is not enforced in practice)'. In the context of CompTIA Security+ (SY0-701), a Gap Analysis compares the current state (as-is) with the desired state (to-be), defined by policies, standards, regulations, or best practices. Here, the two-factor authentication (2FA) policy for all employees is the desired state, but the sales department has been operating with only username and password for over a year. This characterizes an implementation gap (the solution

was not deployed) and operational compliance gap (the policy is not being followed). The control exists formally but is not operational, exposing the organization to unauthorized access risks. The answer directly addresses the discrepancy between the documented requirement and actual practice, which is the core of a compliance Gap Analysis.

✗ Why the others are wrong:

- *Lack of management documentation:* This concept refers to the absence of formal records, such as policies, procedures, minutes, or management reports. In the described scenario, the 2FA policy exists and is documented, as it is mentioned as a requirement. Therefore, there is no lack of management documentation. The problem is not the absence of a document, but rather the non-application of what is already documented. The gap is in execution, not in formalization.
- *Hardware failure in the database server:* A hardware failure involves physical defects in components such as disks, memory, processors, or power supplies, affecting the availability or integrity of a system. The statement does not mention any infrastructure problem, server unavailability, or database errors. The issue is strictly about the adoption of an authentication control (2FA) by sales users. Therefore, the alternative is completely disconnected from the context and does not represent an information security gap in Gap Analysis terms.
- *Incompatibility with labor laws:* Labor laws regulate employment relationships, rights and duties of employees and employers, such as working hours, vacations, wages, etc. Although information security can have legal implications, the requirement of 2FA for all employees does not, as a rule, conflict with labor legislation. The statement does not indicate any legal dispute or legal impediment. The gap is technical and operational in nature, not legal. Therefore, the alternative does not apply to the described problem.

7) A — In the initial planning and diagnostic phase, before acquiring new solutions.

✓ Why it is correct: The correct answer is 'In the initial planning and diagnostic phase, before acquiring new solutions'. According to the information security program lifecycle (aligned with Security+ SY0-701 Domain 1, which covers governance, risk, and compliance), a Gap Analysis is a diagnostic tool that should be conducted at the beginning of strategic planning. It identifies the current state, compares it to the desired state (frameworks such as NIST CSF, ISO 27001, CIS Controls), and thereby directs investments and efforts rationally. Performing it before acquiring solutions avoids unnecessary spending on technologies that do not address real gaps. Therefore, the initial planning and diagnostic phase is the priority time for its execution.

✗ Why the others are wrong:

- *Only after a large-scale cyberattack:* Conducting a Gap Analysis only after a severe incident is a reactive approach contrary to risk management best practices. Gap analysis should be proactive, part of continuous security planning, to prevent incidents. Although a post-incident analysis can be useful to identify failures, it is not the priority time. This alternative ignores the preventive and strategic nature of Gap Analysis, limiting it to crisis response.
- *At the definitive closure of the company's operations:* Gap Analysis at the closure of operations makes no sense in the context of an information security program, whose goal is to protect assets during operation. At that phase, the focus would be secure data disposal, access revocation, and compliance with legal retention requirements. Gap analysis aims to improve security posture while the company is active. Therefore, this alternative is absurd and does not align with the tool's purpose.
- *Exclusively before hiring interns:* Hiring interns is a specific HR event and not a milestone in the security program lifecycle. Although background checks and training for new employees are important, this does not justify exclusively executing a Gap Analysis. Gap analysis is a broad process covering the entire organization and should occur in strategic planning phases, not

restricted to a single type of hiring. This alternative is reductionist and does not reflect the tool's scope.

8) A — CMMI (Capability Maturity Model Integration) with levels 1 to 5.

✓ **Why it is correct:** The correct answer is 'CMMI (Capability Maturity Model Integration) with levels 1 to 5'. CMMI is a maturity model widely used in information security to assess and measure process evolution. Its levels (1 - Initial, 2 - Managed, 3 - Defined, 4 - Quantitatively Managed, 5 - Optimizing) provide an objective scale for Gap Analysis reports, allowing the organization to visualize its progress over time. In the context of CompTIA Security+ (SY0-701), understanding maturity models is part of the governance and risk assessment domain. Therefore, CMMI is the appropriate indicator to measure the maturity of security processes.

✗ **Why the others are wrong:**

- *Log file size in Gigabytes:* Log file size is a data volume metric, not a process maturity metric. Logs can be large due to verbose configurations, extended retention, or high traffic, with no relation to the effectiveness or evolution of security controls. A Gap Analysis seeks to assess adherence to practices and the ability to manage risks, not record storage. Therefore, this metric is irrelevant for measuring maturity.
- *Number of emails received by the board of directors:* The number of emails received by the board is a metric of internal communication or administrative workload, with no connection to information security maturity. It may even indicate management problems, but it does not evaluate security processes. Gap Analysis focuses on controls, policies, and security practices, not on executive correspondence volume. Thus, the alternative does not apply.
- *Download speed of the fiber connection:* Download speed is a network performance metric related to bandwidth and link quality. Although a fast connection can facilitate the implementation of controls, it does not measure the maturity of security processes. An organization can have ultra-fast internet and still have immature security processes. Therefore, this metric is inadequate for Gap Analysis reports that aim to measure process evolution.

9) A — Based on business risk impact, likelihood of occurrence, and mandatory regulatory requirements.

✓ **Why it's correct:** The correct answer is 'Based on business risk impact, likelihood of occurrence, and mandatory regulatory requirements'. Prioritizing remediation in a security plan should follow a risk management approach, as advocated by CompTIA Security+ (SY0-701). The CISO should evaluate each gap considering: (1) the potential impact on business objectives, critical assets, and reputation; (2) the likelihood of exploitation or occurrence; and (3) the existence of legal, regulatory, or contractual requirements that make remediation mandatory. This analysis allows efficient resource allocation, addressing the most significant risks first. The answer reflects exactly this structured process aligned with best practices.

✗ **Why the others are wrong:**

- *Remediating only the easiest and quickest tasks first:* This approach, known as 'quick wins', may be useful for gaining momentum but is not adequate as the primary prioritization criterion. It ignores the risk associated with each gap. An easy task may have insignificant impact, while a difficult one may represent catastrophic risk. Prioritizing only by ease can leave critical vulnerabilities unaddressed, exposing the organization to severe incidents. Therefore, it is an insufficient strategy contrary to risk management.
- *By the highest cost of tools available on the market:* The cost of tools is not an indicator of risk or priority. An expensive tool may not be the most suitable for mitigating a specific gap, and its high cost may consume resources without addressing the most pressing risks. Prioritization should be based on risk, not price. Additionally, low-cost solutions can be highly effective. Therefore, this

alternative is economically irrational and does not meet security management principles.

- *In alphabetical order of the affected department names:* Alphabetical order is an arbitrary criterion with no relation to the criticality of the gaps. Departments with names starting with 'A' may have lower risks than others with 'Z'. Prioritization should consider business impact, likelihood, and regulatory requirements, not nomenclature. This approach would completely ignore risk analysis and could leave the most critical areas unprotected. Therefore, it is an absurd and unprofessional option.

10) A — Identify security weaknesses in the acquired company that could compromise the acquiring company's network.

✓ **Why it is correct:** The correct answer is 'Identify security weaknesses in the acquired company that could compromise the acquiring company's network'. In mergers and acquisitions, cybersecurity due diligence is essential. A mutual Gap Analysis allows the acquiring company to assess the security posture of the acquired startup, identifying vulnerabilities, missing controls, regulatory compliance gaps, and possible backdoors or malware. The goal is to prevent the integration of networks from propagating risks to the acquirer's infrastructure. CompTIA Security+ (SY0-701) addresses the importance of third-party risk assessment and due diligence. Therefore, the answer aligns with security best practices in M&A.

✗ **Why the others are wrong:**

- *Reduce the salaries of the startup's engineers:* Salary reduction is a labor and human resources issue, not information security. A security Gap Analysis has no relation to compensation policies. The objective is technical: to assess cyber risks. Therefore, this option is completely irrelevant and does not apply to the context of security due diligence.
- *Install spyware to monitor the conversations of the acquired team:* Installing spyware is illegal, unethical, and contrary to any information security principle. Due diligence aims to protect both parties, not spy on employees. Additionally, CompTIA Security+ emphasizes ethics and legal compliance. Therefore, this option is absurd and criminal, not representing the objective of the Gap Analysis.
- *Erase the email history of the acquired company:* Deleting emails would be destruction of evidence and would violate legal retention and compliance requirements. Due diligence seeks to preserve and analyze information to assess risks, not eliminate it. Network integration requires transparency and auditing. Therefore, this option is counterproductive and illegal, not aligning with the purpose of the gap analysis.